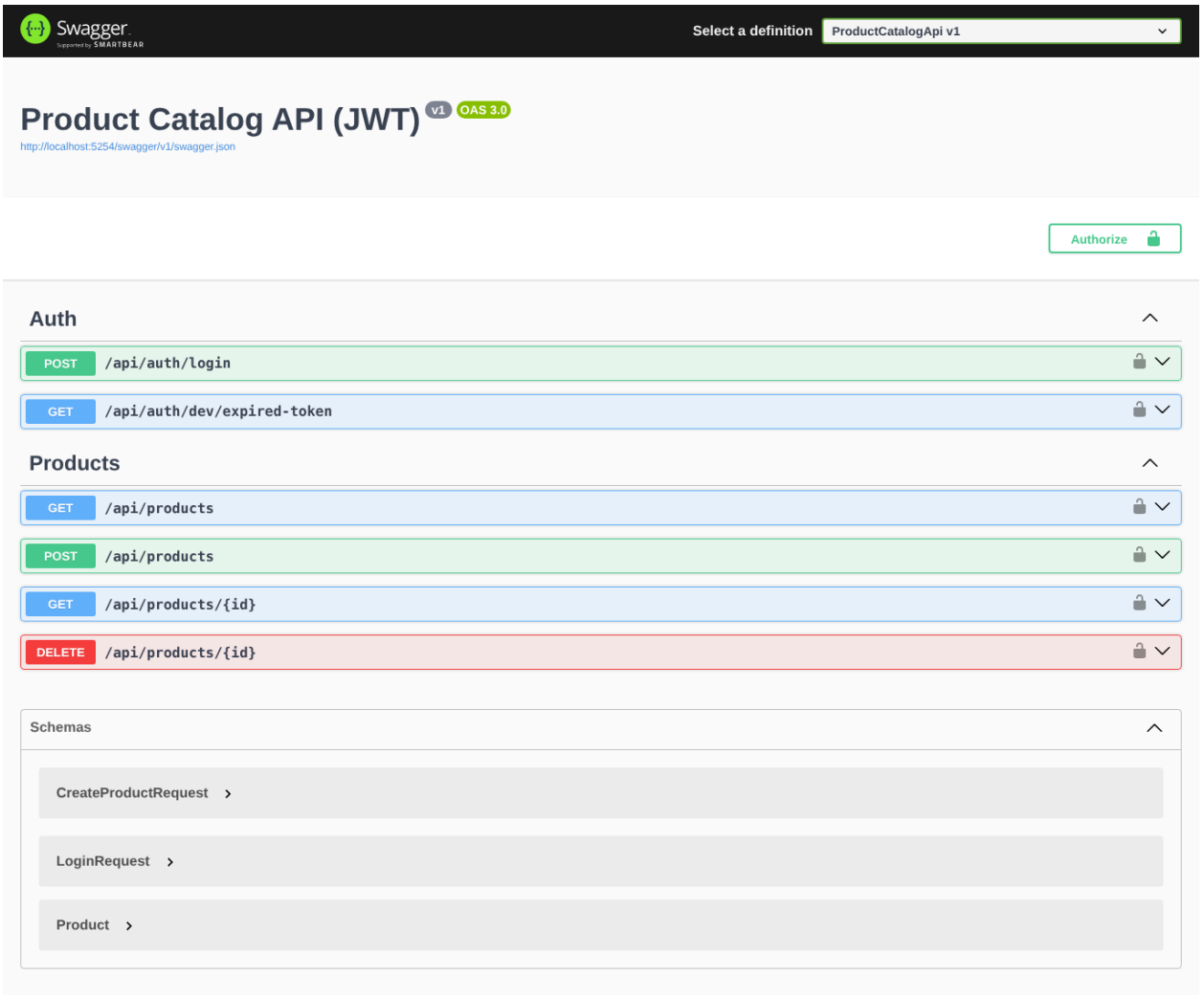
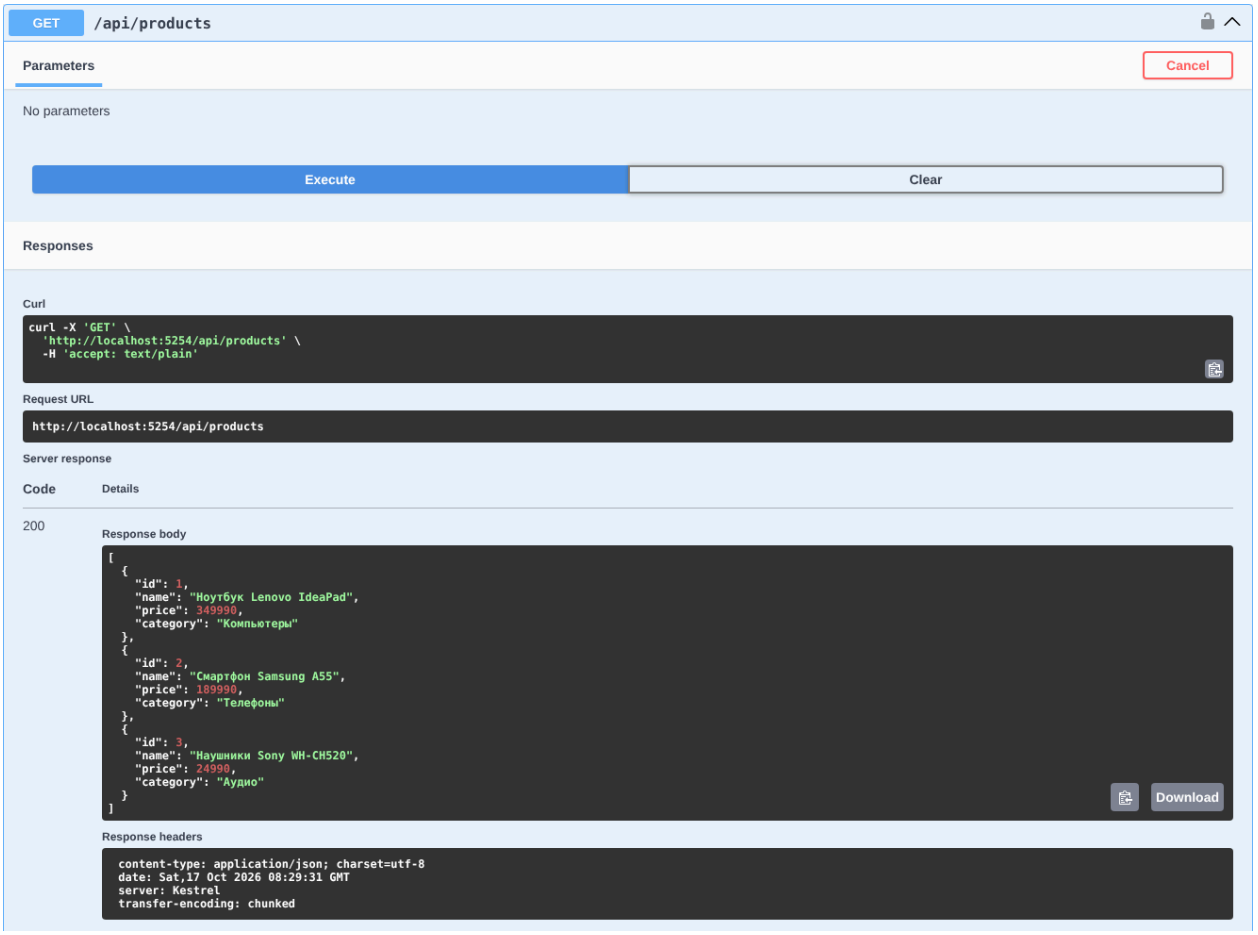
1. Swagger UI проекта



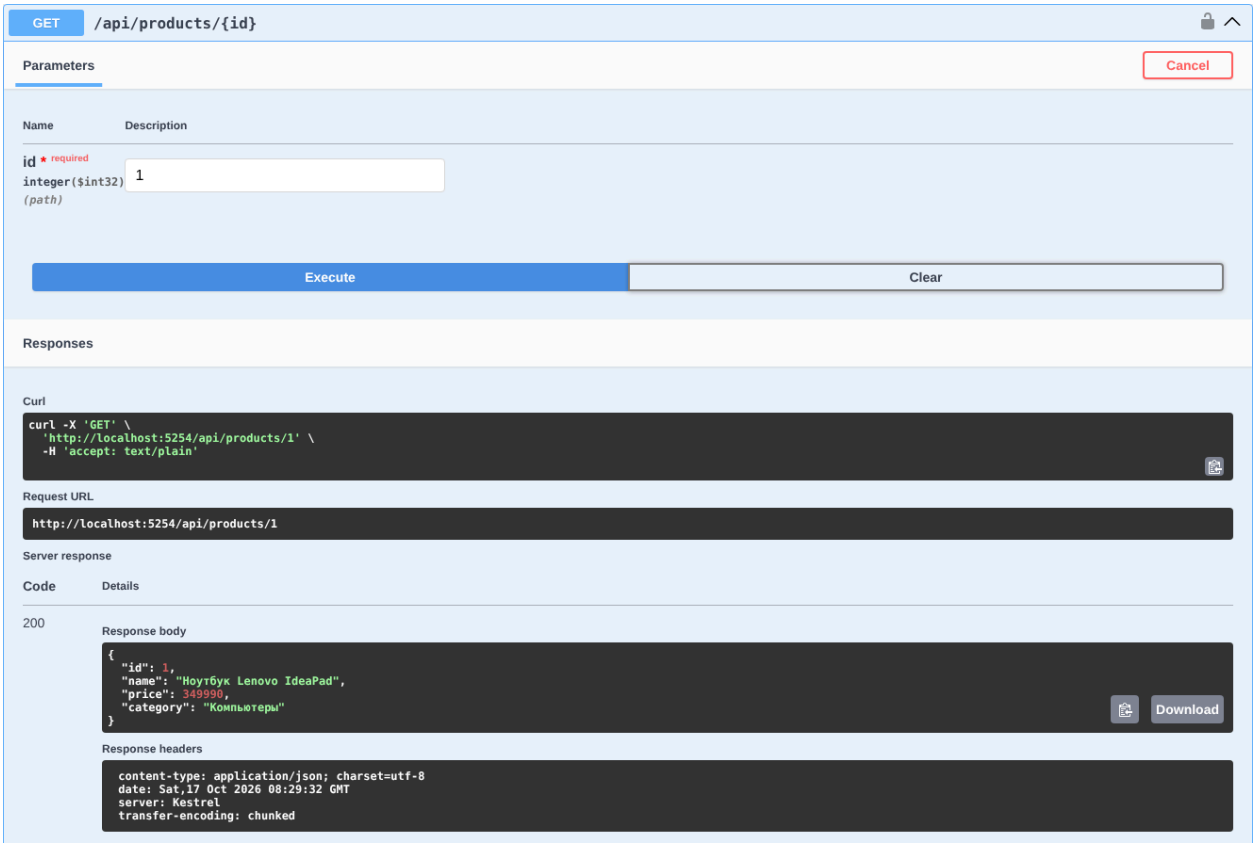
Swagger UI ProductCatalogApi: методы Auth и Products

GET /api/products список товаров

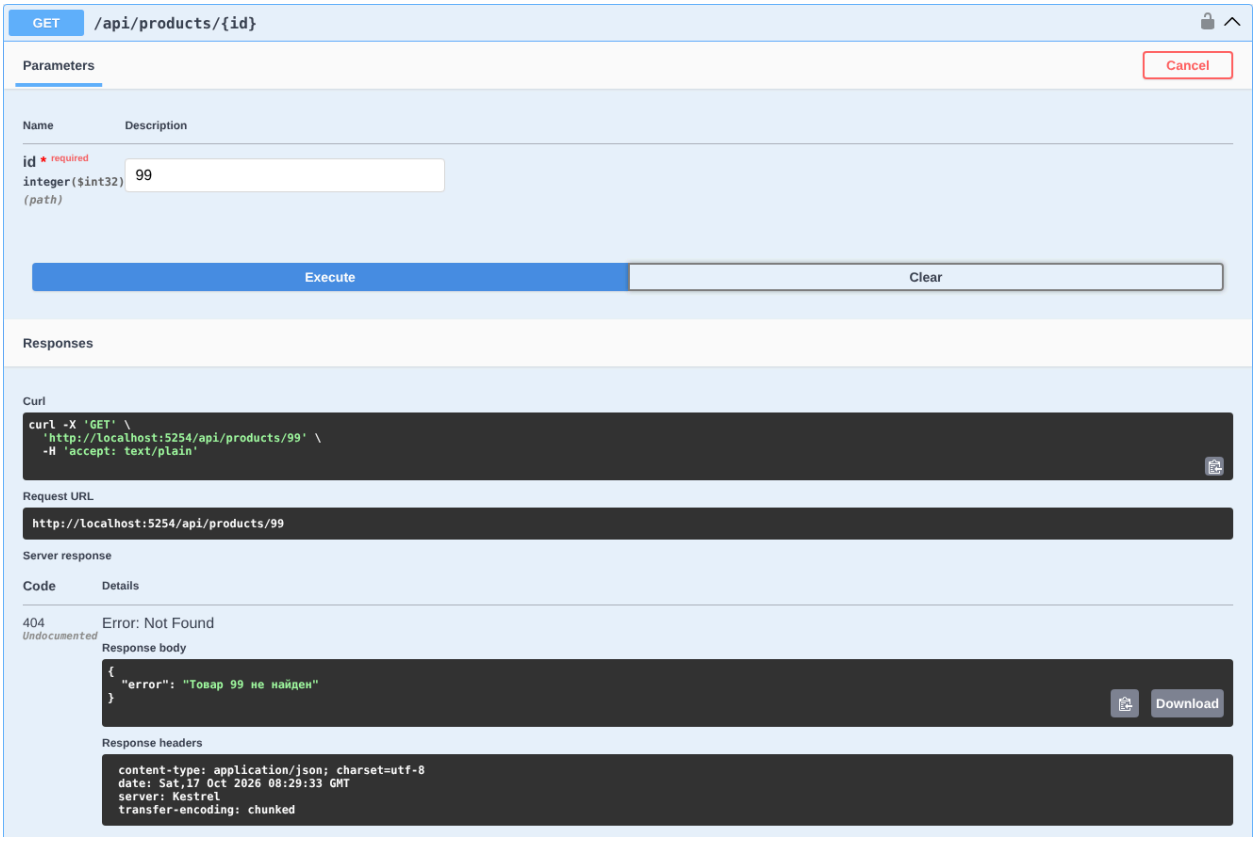


GET /api/products без токена 200 OK, список товаров открыт всем

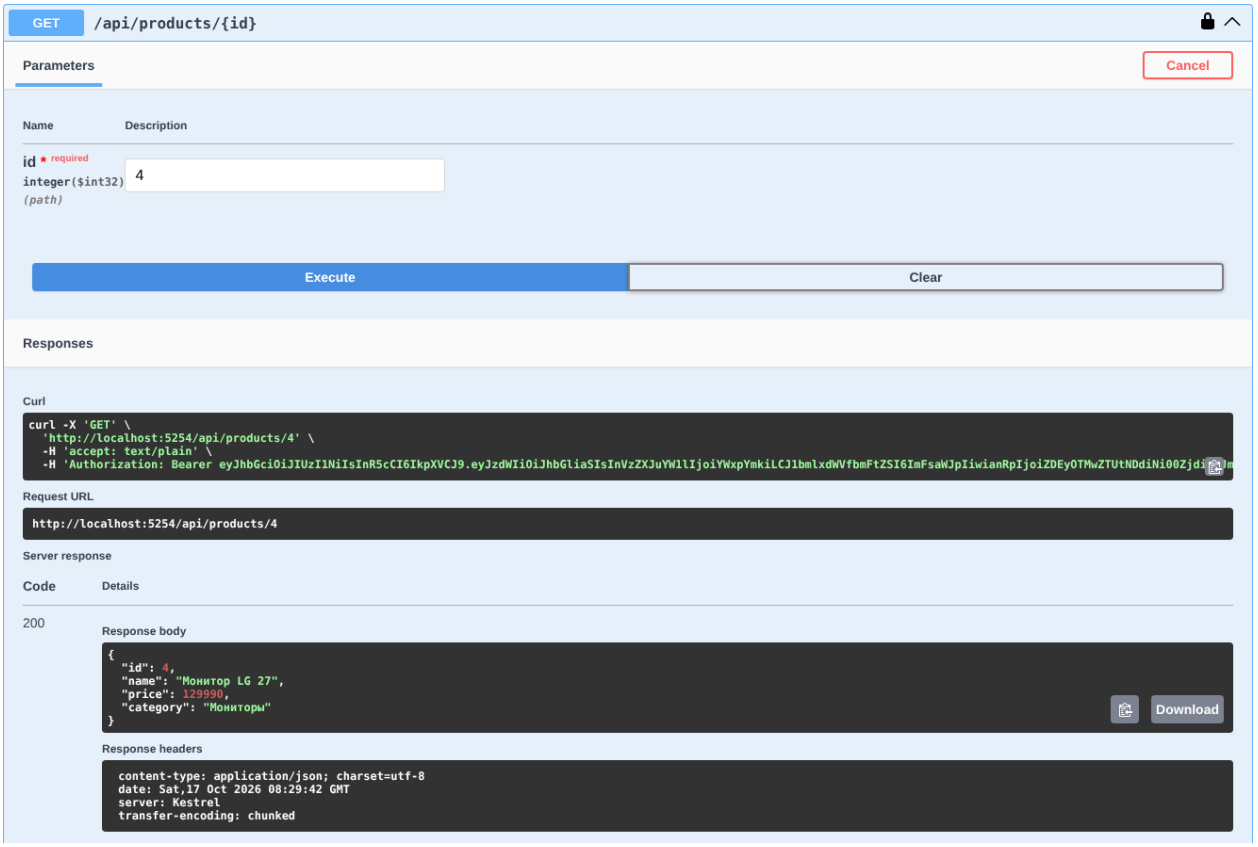
GET /api/products/{id} товар по id



GET /api/products/1 без токена 200 OK, товар найден

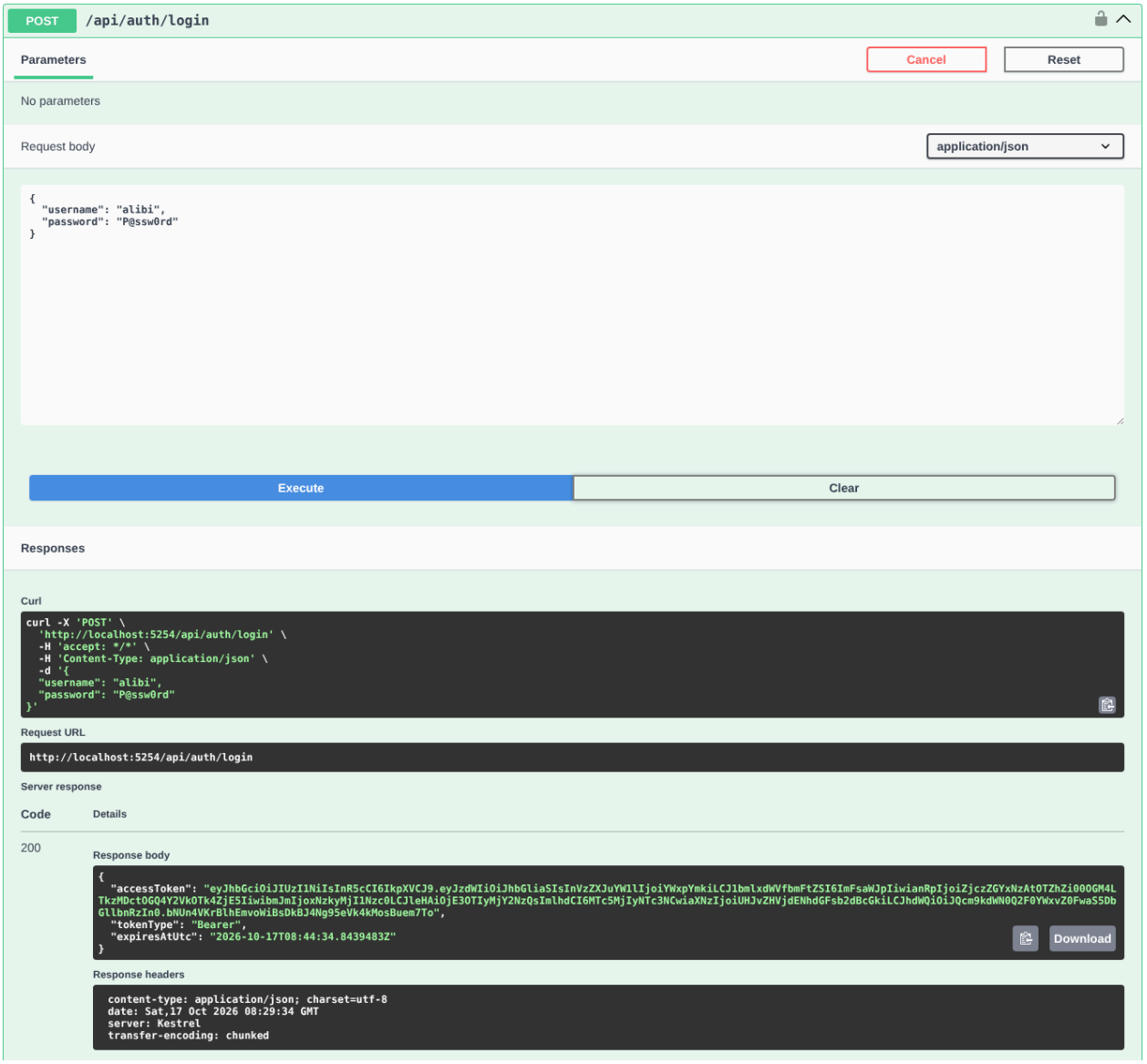


GET /api/products/99 404 Not Found, товар не найден

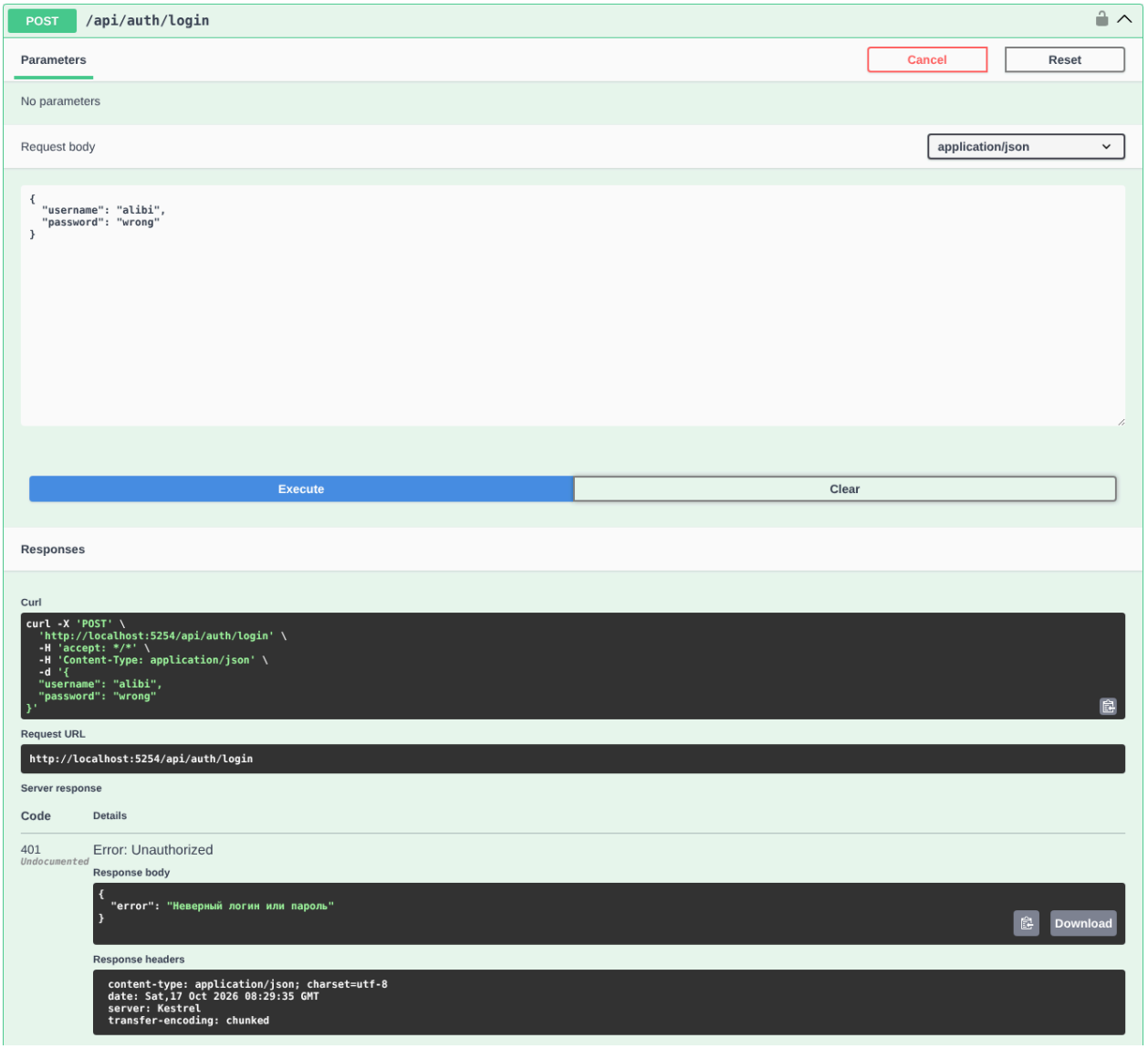


GET /api/products/4 200 OK, добавленный товар доступен

POST /api/auth/login вход и получение JWT

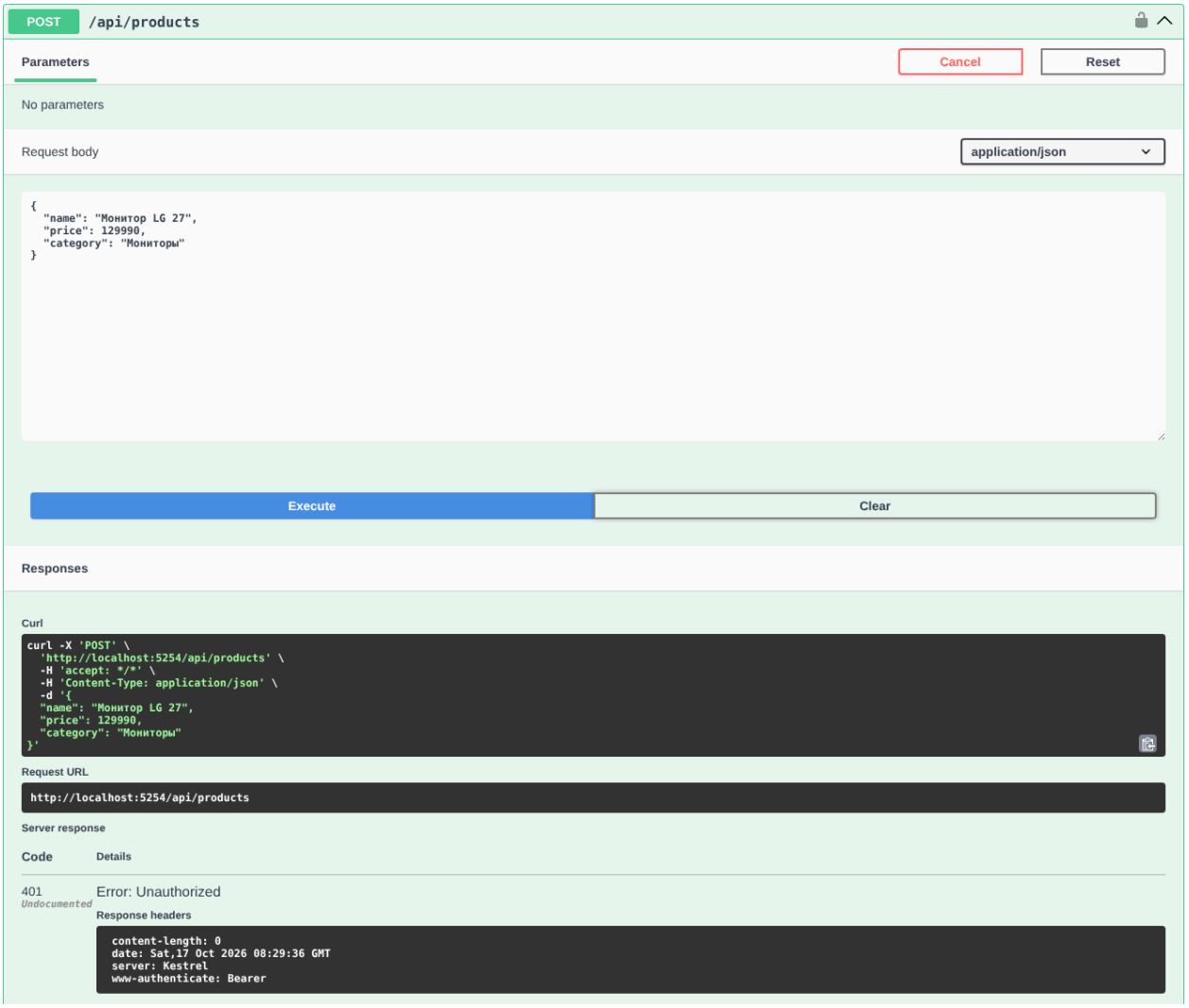


POST /api/auth/login (alibi / P@ssw0rd) 200 OK, получен accessToken

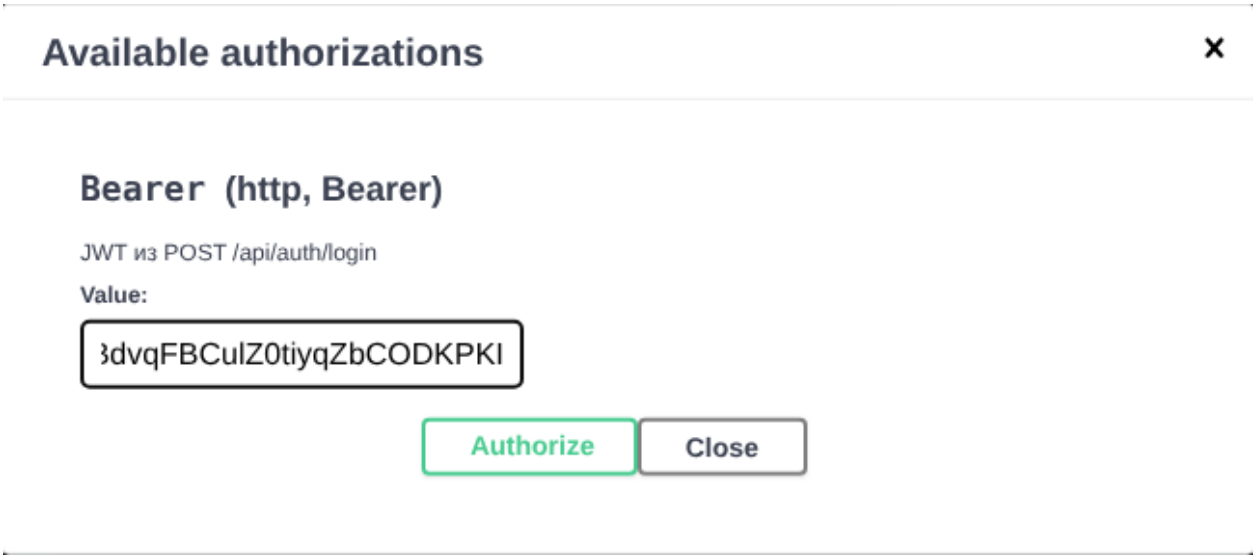


POST /api/auth/login с неверным паролем 401 Unauthorized

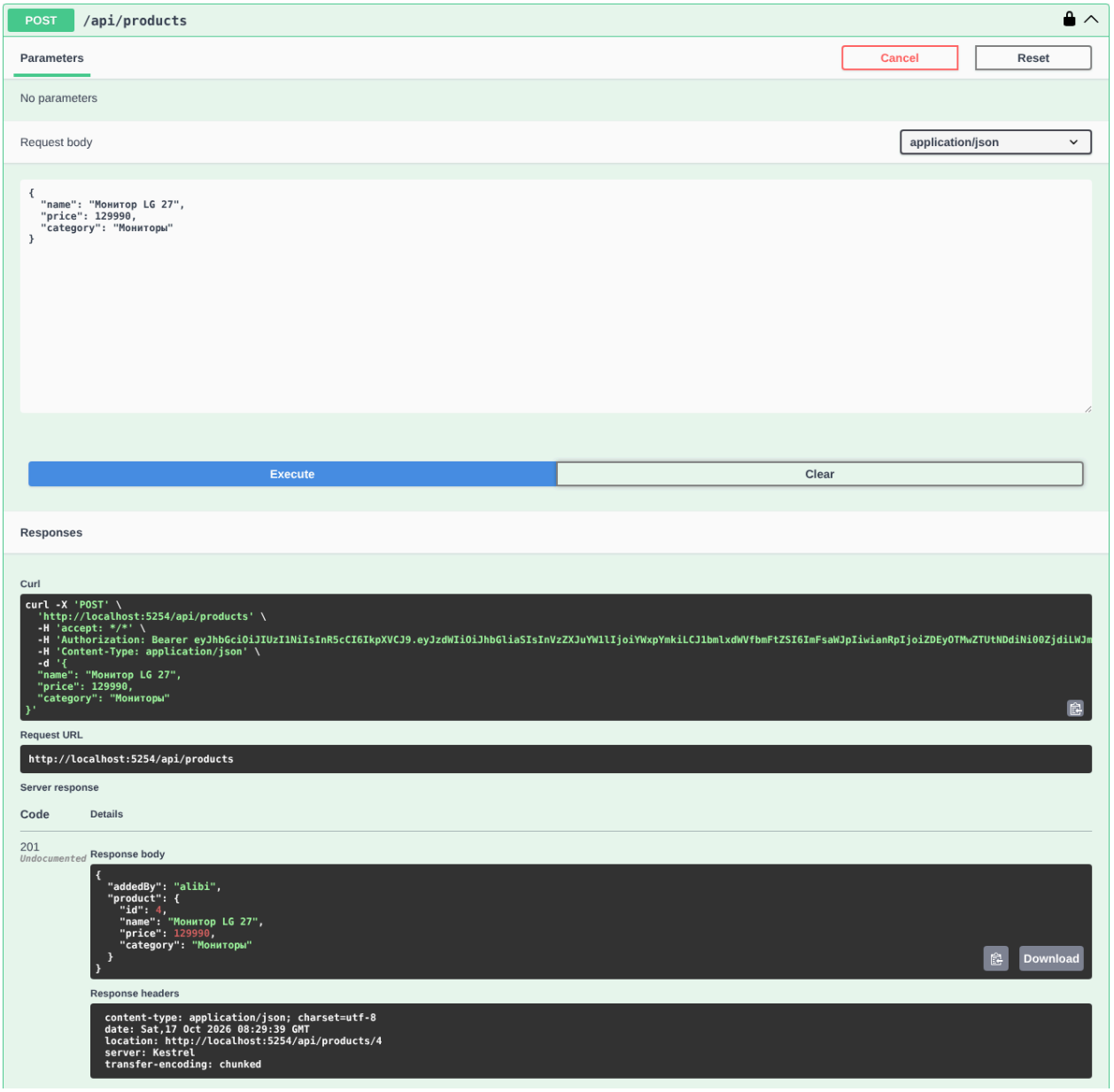
5. POST /api/products добавление товара (только JWT)



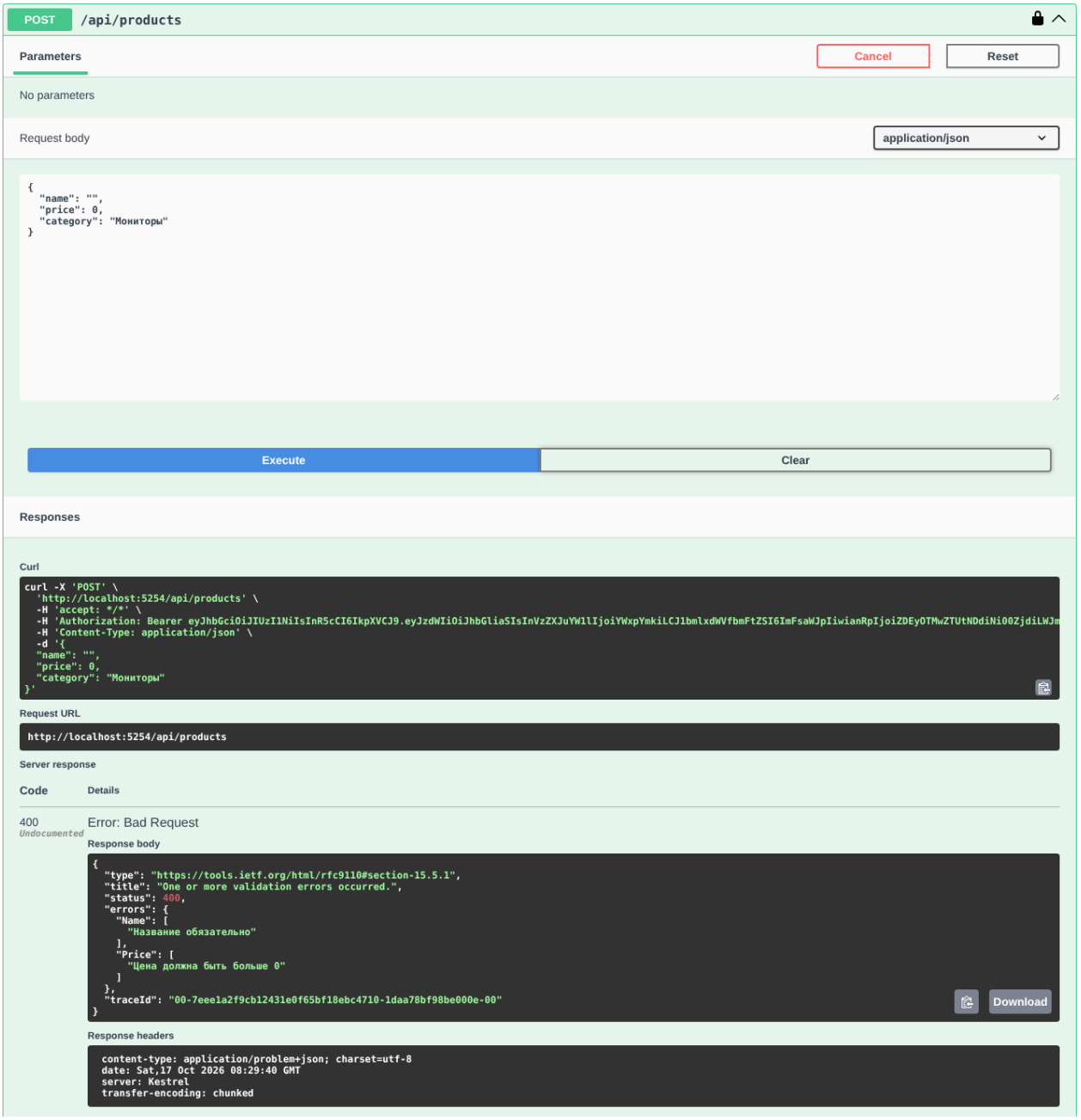
POST /api/products без токена 401 Unauthorized



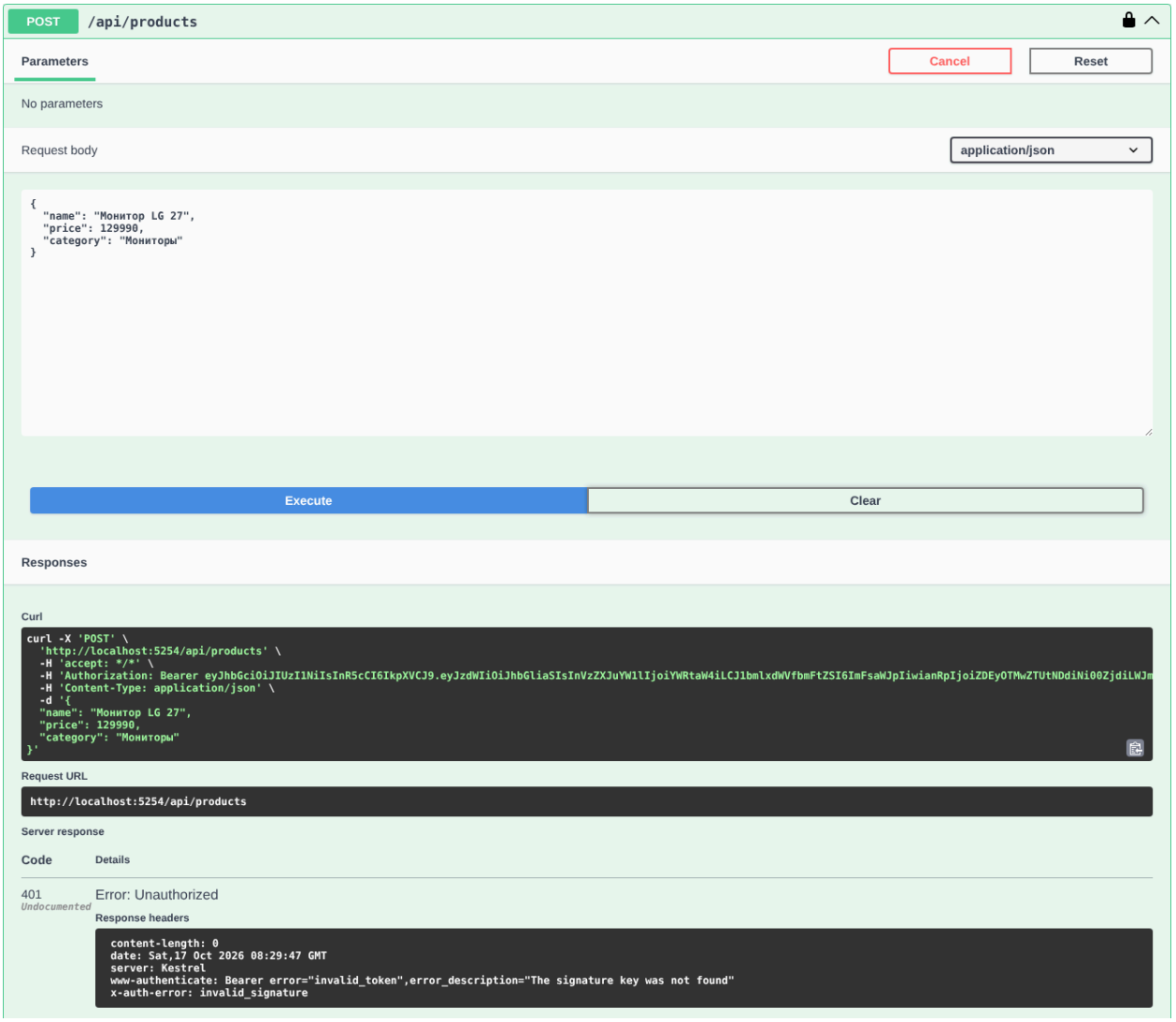
Окно Authorize: ввод JWT-токена пользователя alibi



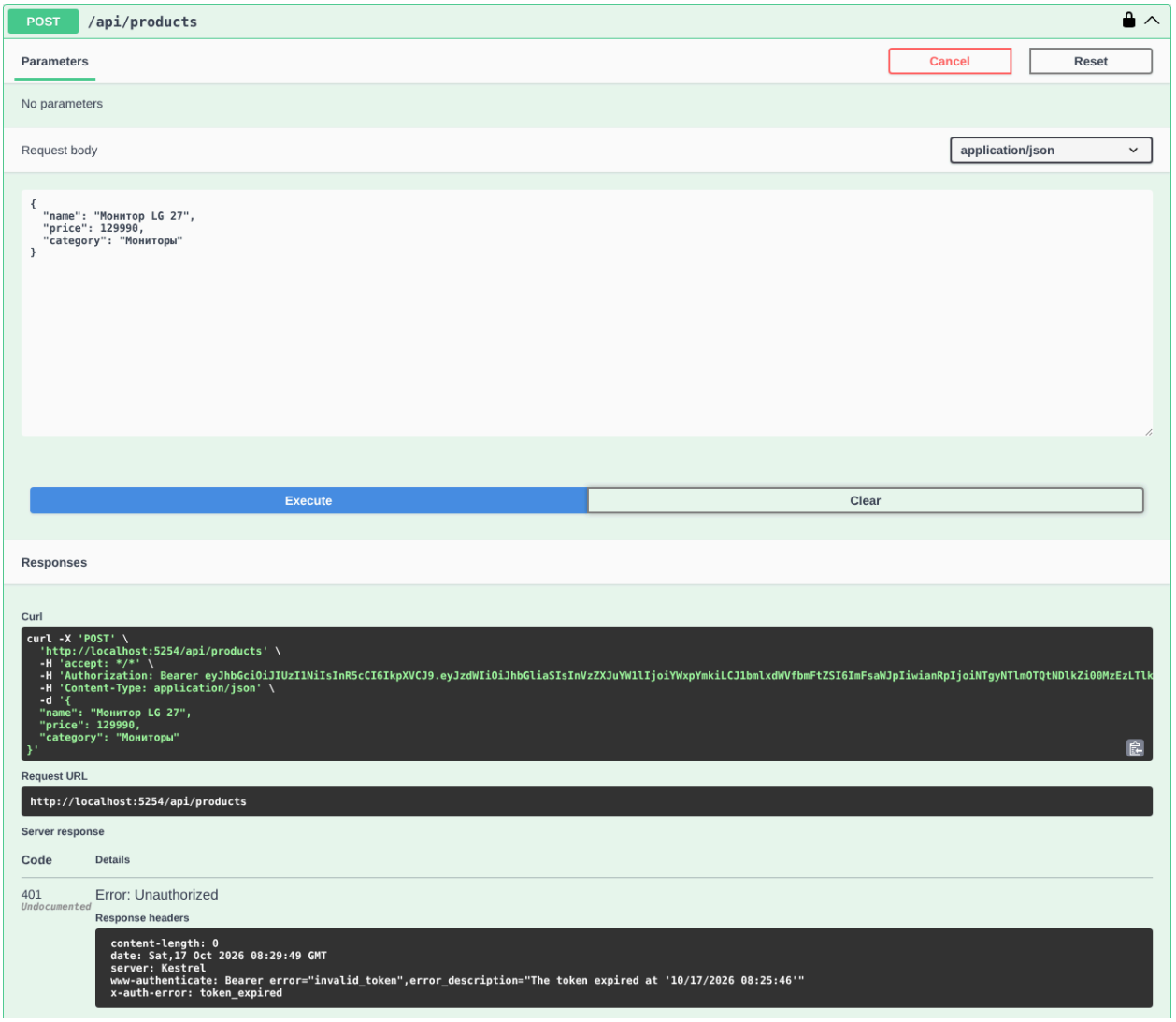
POST /api/products с токеном 201 Created, addedBy: alibi (Claim username)



POST /api/products с пустым названием и ценой 0 400 Bad Request, ошибки валидации

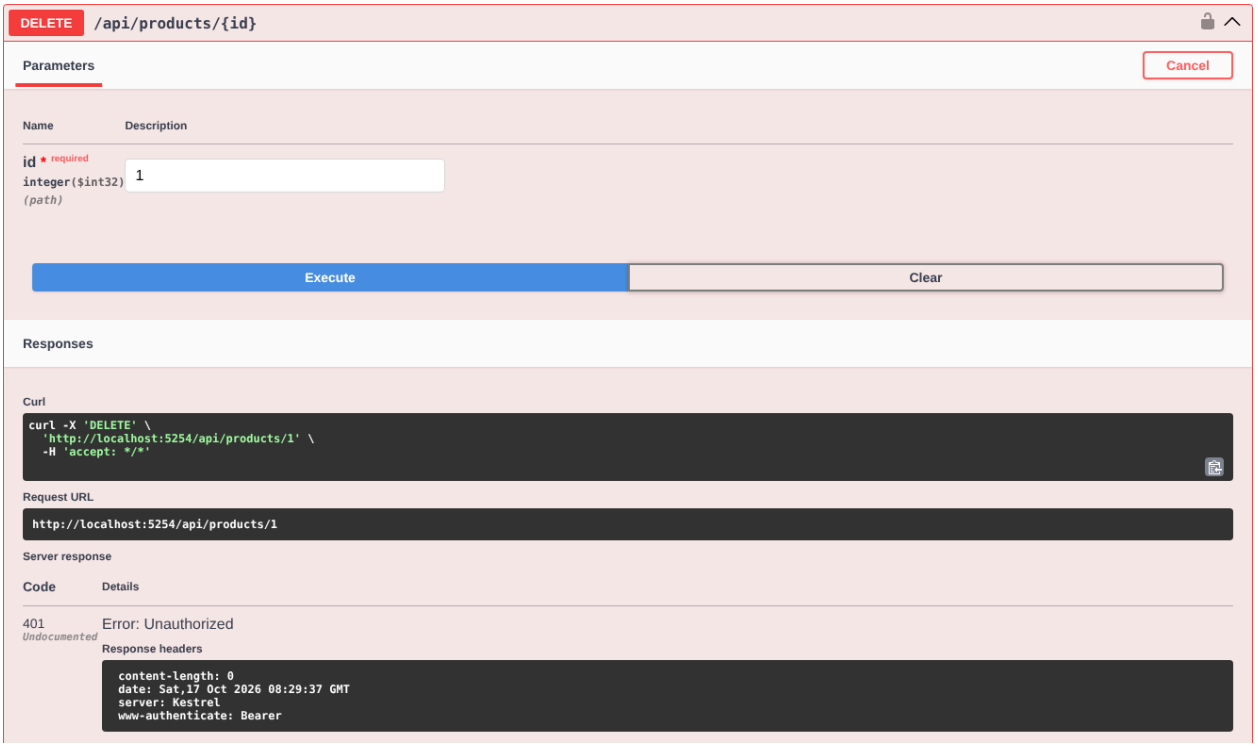


POST /api/products с изменённым токеном (username: alibi - admin) 401, x-auth-error: invalid_signature

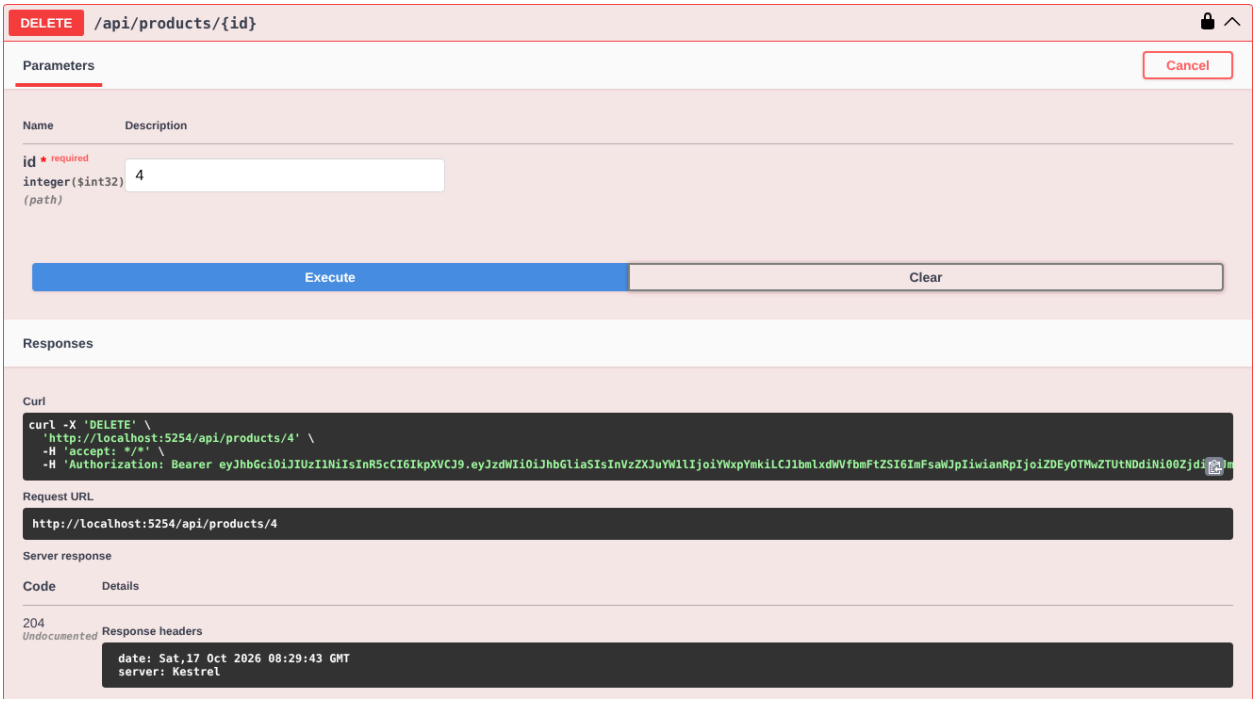


POST /api/products с просроченным токеном 401, x-auth-error: token_expired

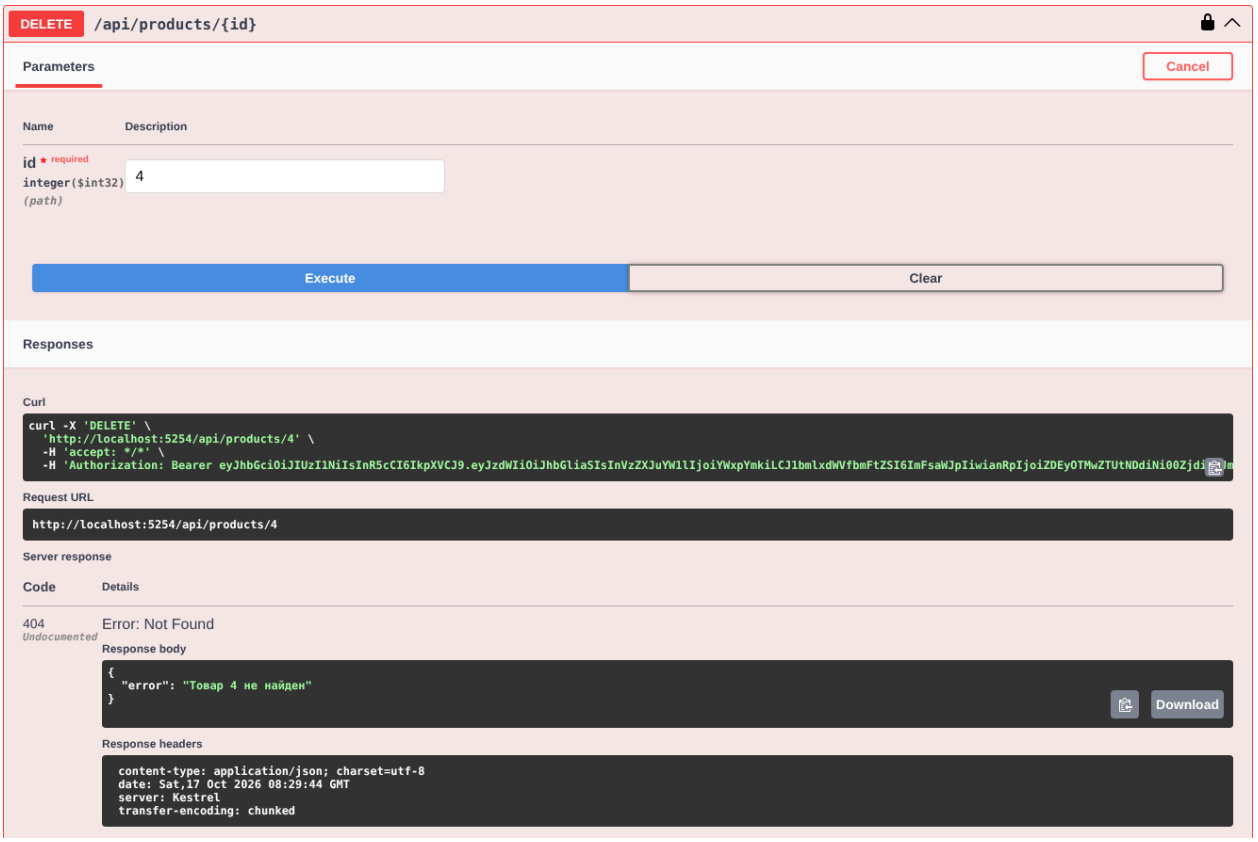
DELETE /api/products/{id} удаление товара (только JWT)



DELETE /api/products/1 без токена 401 Unauthorized

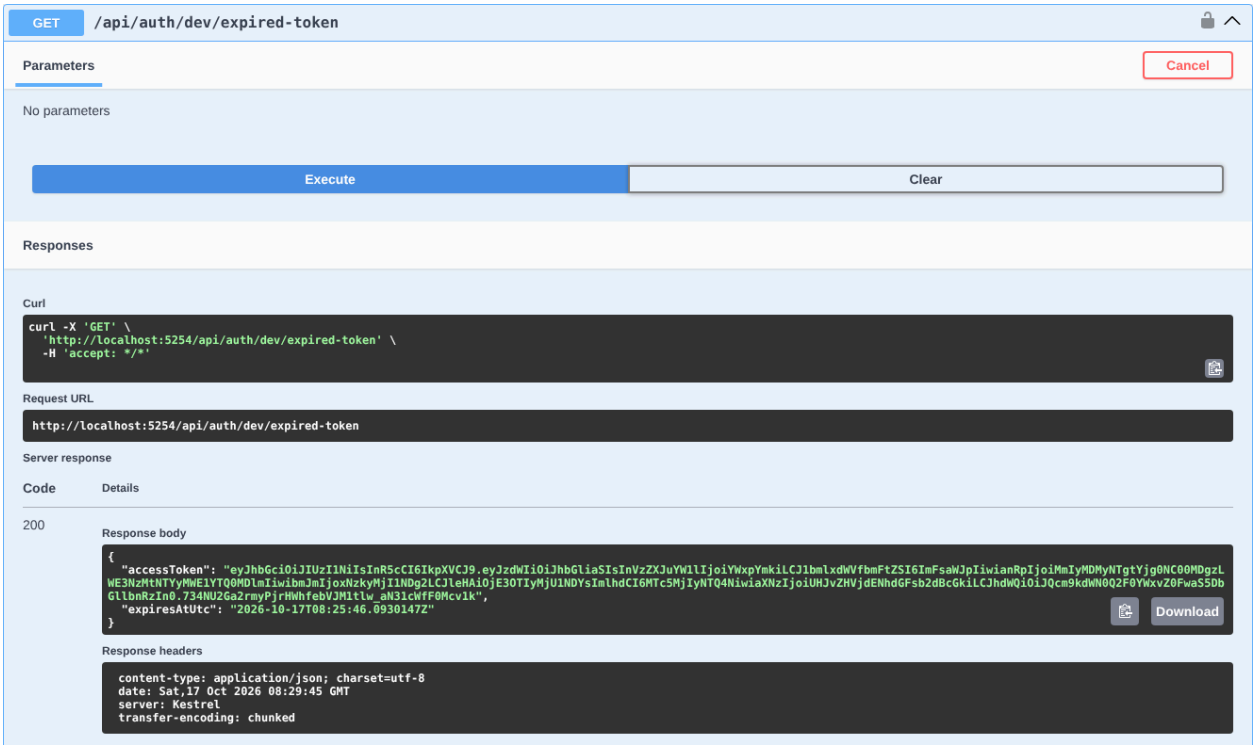


DELETE /api/products/4 с токеном 204 No Content, товар удалён



DELETE /api/products/4 повторно 404 Not Found

GET /api/auth/dev/expired-token тестовый просроченный токен



GET /api/auth/dev/expired-token 200 OK, выдан просроченный токен (только Development)

Контрольные вопросы

Почему секретный ключ JWT не передаётся клиентом вместе с запросом?

Ключом сервер подписывает токены. Тот, кто знает ключ, может сам выпустить токен на любого пользователя. Поэтому ключ хранится только на сервере, а клиент передаёт выданный ему токен, подпись которого сервер проверяет своим ключом.

Как сделать, чтобы часть методов была открытой, а часть защищённой?

Атрибут [Authorize] ставится на весь контроллер, а открытые методы помечаются [AllowAnonymous]. Тогда любой новый метод по умолчанию будет защищён, и его нельзя случайно оставить открытым.

Как получить данные пользователя внутри защищённого метода?

После успешной проверки токена JwtBearer заполняет HttpContext.User. Его Claims доступны через HttpContext.User.Claims: например, FirstOrDefault(c => c.Type == "username") возвращает имя пользователя.

Почему просроченный токен даёт 401, а не 403?

401 Unauthorized означает, что пользователь не аутентифицирован: токен недействителен, и личность не подтверждена. 403 Forbidden используется, когда личность подтверждена, но прав на действие недостаточно.ы